

FedGuard: A Governance Framework for Secure and Regulation-Compliant Federated Learning

Shariq Shaikh

Department of Computer Science
SIES College of Arts, Science and Commerce
Mumbai, India
shariqshaikh11042004@gmail.com

Maya Nair

Department of Computer Science
SIES College of Arts, Science and Commerce
Mumbai, India
mayanair@gmail.com

Abstract—Federated Learning (FL) enables multi-institutional collaborative machine learning without centralizing raw data, offering a powerful paradigm for privacy-preserving artificial intelligence. However, mainstream FL frameworks focus predominantly on model distribution and communication efficiency, lacking systemic infrastructure for regulatory compliance, dynamic policy enforcement, participant verification, and immutable auditability required in enterprise environments (e.g., HIPAA, GDPR).

This paper introduces FedGuard, a policy-driven governance control plane designed to enforce regulatory compliance, security policies, and auditable operational guarantees across the federated learning lifecycle. To demonstrate feasibility, we present Conclave, a production-grade reference implementation integrating FedGuard with the Flower FL framework. Conclave incorporates X25519-based threshold Secure Aggregation with Shamir secret sharing for dropout-resilient mask cancellation, Rényi Differential Privacy (RDP) accounting for cumulative budget tracking, mTLS identity verification with fine-grained access control (RBAC/ABAC), and SHA-256 hash-chained tamper-evident audit ledgers. Furthermore, it supports Byzantine-robust aggregation algorithms (Trimmed Mean, Median, Krum) to mitigate adversarial poisoning attacks under realistic non-IID data distributions (Dirichlet $\alpha = 0.5$).

Empirical evaluation on deep learning workloads (ResNet-18 on CIFAR-10) demonstrates that FedGuard guarantees end-to-end policy compliance, real-time participant revocation, and tamper-proof auditability while incurring minimal computational and communication overhead relative to ungoverned FL baselines. Conclave provides a practical and extensible foundation for trustworthy enterprise federated learning in strictly regulated domains.

Index Terms—Federated Learning, Governance, Compliance, Auditability, Policy Enforcement, Enterprise AI

I. INTRODUCTION

The rapid proliferation of Artificial Intelligence (AI) and Deep Learning across data-sensitive domains—such as healthcare, medical diagnostics, financial fraud detection, and smart manufacturing—has highlighted an imperative requirement for collaborative model training [1]. Traditional machine learning paradigms rely on centralized data aggregation, wherein raw datasets from multiple institutional entities are transmitted to a unified repository. However, this centralized architecture introduces critical vulnerabilities, including catastrophic data breaches, violation of patient or customer confidentiality, and non-compliance with strict statutory privacy laws such as

the U.S. Health Insurance Portability and Accountability Act (HIPAA) [2] and the European Union General Data Protection Regulation (GDPR) [3].

Federated Learning (FL) has emerged as a landmark distributed paradigm that enables collaborative model training without raw data centralization [4], [5]. In a standard FL topology, participating institutions (clients) maintain local datasets and execute iterative model training on local compute nodes. Rather than exposing raw data, clients transmit only intermediate model updates (e.g., gradients or weight tensors) to a central parameter server for global aggregation. By restricting raw data to local host boundaries, FL provides an intuitive foundation for privacy-preserving distributed intelligence across geographically dispersed organizations.

A. Motivation and Enterprise Governance Gaps

Despite its theoretical advantages, mainstream FL frameworks—such as Flower [6], NVIDIA FLARE [7], TensorFlow Federated [5], OpenFL [8], FedML [9], FATE [10], and PySyft [11]—focus predominantly on model orchestration, communication compression, and distributed training efficiency. Consequently, they treat enterprise governance, regulatory compliance, access control, and auditable operational guarantees as out-of-scope concerns. In enterprise and regulated deployments, this technical void presents critical barriers to adoption:

- 1) **Absence of Dynamic Policy Enforcement and Compliance Mapping:** Standard FL orchestrators lack native mechanisms to enforce organizational rules, verify local node compliance (e.g., hardware TPM 2.0 / TEE attestation quotes [12], mTLS certificates), or map system operations to statutory regulatory mandates (e.g., HIPAA Security Rule Section 164.312 [2] and GDPR Articles 5, 7, 17, and 32 [3]).
- 2) **Inflexible Cryptographic and Privacy Control:** Unmasked parameter updates are vulnerable to gradient inversion attacks that reconstruct raw input data [13], [14]. Conventional FL deployments either omit privacy guarantees entirely or rely on basic additive masking that fails under client dropouts. They lack threshold secret sharing for dropout-resilient mask reconstruction [15],

[16], as well as formal differential privacy budget accounting (e.g., Rényi Differential Privacy [18], [19]) to track cumulative privacy leakage (ϵ, δ) across multi-round training sessions.

- 3) **Lack of Immutable Auditability and Certified Machine Unlearning:** Enterprise FL systems require tamper-evident audit trails to prove regulatory compliance to external auditors. Furthermore, under GDPR Article 17 (Right to Erasure), FL systems must support real-time participant revocation and automated machine unlearning protocols [28]–[30] without corrupting global model state or compromising surviving nodes.
- 4) **Susceptibility to Adversarial Poisoning under Skewed Distributions:** Real-world multi-institutional datasets exhibit severe statistical heterogeneity (non-IID data distributions modeled via Dirichlet distribution $\text{Dir}(\alpha)$) [23], [24]. Standard federated averaging algorithms (FedAvg) degrade significantly in accuracy and are highly vulnerable to Byzantine poisoning attacks (e.g., sign-flipping or gradient corruption [25], [27]) executed by compromised nodes.

B. Proposed Solution: FedGuard and Conclave Control Plane

To bridge the fundamental divide between distributed model training and enterprise regulatory requirements, this paper presents **FedGuard**, a framework-agnostic policy-driven governance control plane for Federated Learning. FedGuard establishes an independent operational governance layer that enforces participant identity verification, automated compliance checks, granular access control, privacy budget tracking, and tamper-evident audit logging throughout the FL training lifecycle.

To evaluate the practical efficacy of our proposed architecture, we implement **Conclave**, a production-grade reference implementation that integrates FedGuard with the Flower FL framework. Conclave abstracts governance as a modular control plane operating alongside the Flower orchestrator. The technical core of Conclave features:

- **Threshold Secure Aggregation:** An ephemeral X25519 Key Agreement protocol coupled with Shamir’s Secret Sharing [15], [17], enabling k -of- N surviving nodes to reconstruct dropped clients’ pairwise masks and cancel them without revealing active client updates.
- **Formal Privacy Accounting:** A Rényi Differential Privacy (RDP) accountant [18] combined with Gaussian noise injection to track cumulative (ϵ, δ) privacy budget consumption per organization across multi-tenant training rounds.
- **Cryptographic Audit Ledger:** A SHA-256 hash-chained tamper-evident event log (audit event ledger) that cryptographically links all governance events, policy checks, and consent revocations.
- **Byzantine Resilience under Non-IID Data:** Integration of robust aggregation primitives (Trimmed Mean, Median, and Krum [25], [26]) paired with deterministic

Dirichlet non-IID partitioning ($\alpha = 0.5$) for deep learning workloads (ResNet-18 on CIFAR-10).

C. Summary of Key Contributions

The primary contributions of this work are summarized as follows:

- **Decoupled Governance Control Plane Architecture (FedGuard):** We formalize a comprehensive, policy-driven governance control plane for Federated Learning that decouples regulatory enforcement, policy validation, and auditability from the underlying distributed ML execution engine (e.g., Flower [6]).
- **Automated Statutory Compliance Engine & Attestation Mapping:** We design an automated compliance engine that verifies client identity, privacy budget limits, and hardware root-of-trust (TPM 2.0 / TEE Remote Attestation quotes [12]) against statutory regulatory mandates, establishing formal policy mappings for U.S. HIPAA (§164.312) [2] and EU GDPR (Articles 5, 7, 17, and 32) [3].
- **Dual Security Mode Formalization:** We identify and resolve the fundamental protocol incompatibility between Secure Aggregation update masking and coordinate-wise Byzantine distance metrics by formalizing explicit governance modes (`SECURE_AGGREGATION` vs. `BYZANTINE_RESILIENT`) with real-time audit ledger logging.
- **Dual-Action GDPR Article 17 Machine Unlearning Protocol:** We propose a comprehensive regulatory enforcement workflow under GDPR Article 17 (Right to Erasure) that pairs real-time client credential eviction with an automated machine unlearning trigger (FedEraser checkpoint purification [28]) to guarantee mathematical data erasure.
- **Tamper-Evident SHA-256 Audit Ledger & Empirical Evaluation:** We incorporate a lightweight SHA-256 hash-chained audit ledger and evaluate our reference implementation, Conclave, on deep learning workloads (ResNet-18 on non-IID CIFAR-10), demonstrating that FedGuard enforces end-to-end governance and Byzantine resilience with only 7.2% runtime overhead.

D. Paper Organization

The remainder of this paper is organized as follows: Section II reviews related literature across federated learning frameworks, cryptographic privacy, Byzantine robustness, and enterprise governance, presenting a comparative taxonomy. Section III details the FedGuard control plane architecture and Conclave reference implementation. Section IV presents the cryptographic Secure Aggregation, Rényi Differential Privacy, and Byzantine resilience protocols. Section V reports empirical evaluation results, including security overhead, scalability, Byzantine resilience, and regulatory compliance benchmarks. Finally, Section VI concludes the paper and outlines future research directions.

II. RELATED WORK & COMPARATIVE TAXONOMY

This section synthesizes recent literature (2021–2025) across federated learning frameworks, cryptographic secure aggregation, differential privacy accounting, Byzantine-robust aggregation, enterprise governance, statutory compliance, and federated identity management, highlighting the technical distinctions of the FedGuard framework.

A. Federated Learning Frameworks and Enterprise Platforms

The development of Federated Learning (FL) software infrastructure has evolved rapidly across academic and industrial domains. Mainstream open-source platforms—such as **Flower** [6], **NVIDIA FLARE** [7], **TensorFlow Federated (TFF)** [5], **OpenFL** [8], **FedML** [9], **Webank FATE** [10], and **PySyft** [11]—have driven significant advances in distributed model orchestration, multi-language client execution, and hardware acceleration.

However, existing platforms exhibit structural limitations when deployed in enterprise environments. Frameworks like Flower and FedML prioritize communication compression and algorithmic scheduling, treating administrative access control and statutory policy enforcement as out-of-scope concerns. Industrial platforms such as NVIDIA FLARE and FATE incorporate transport-layer security (mTLS) and site-based authorization, but their governance modules are monolithically coupled with their proprietary job contracts and execution runtimes. Similarly, OpenFL supports hardware enclaves (Intel SGX), and PySyft enables remote tensor approvals, but neither provides an independent governance control plane capable of enforcing policy rules across heterogeneous execution backends. *In contrast to these platform-specific architectures, FedGuard establishes a framework-agnostic control plane that intercepts lifecycle events via standardized hook abstractions, decoupling governance policy enforcement from the underlying machine learning execution engine.*

B. Secure Aggregation and Cryptographic Protocols

Cryptographic Secure Aggregation (SecAgg) prevents semi-honest parameter servers from inspecting individual client weight updates by adding zero-sum pairwise masks. Unmasked updates expose local model parameters to gradient inversion attacks that can reconstruct original training images or text tokens [13], [14]. Since the foundational threshold SecAgg protocol proposed by Bonawitz et al. [15], recent work has focused on reducing communication and computation overhead. Variants such as SecAgg+ [16] and LightSecAgg [17] leverage graph-based masking, secret sharing optimization, and finite-field vectorization to improve scalability under client dropouts.

While these protocols significantly advance cryptographic efficiency, they treat Secure Aggregation as an isolated mathematical primitive. They lack integration with higher-level enterprise identity mechanisms, automated policy checks, or dynamic session governance. *FedGuard bridges this gap by integrating X25519 Elliptic Curve Diffie-Hellman (ECDH) key agreement with Shamir’s (k, N) -Threshold Secret Sharing directly into a policy-driven lifecycle, ensuring that ephemeral*

masking and dropout recovery are dynamically orchestrated based on validated compliance policies.

C. Differential Privacy and Formal Budget Accounting

Differential Privacy (DP) provides rigorous mathematical bounds against membership inference and model inversion attacks in FL [20], [21]. To account for privacy loss across iterative training rounds, Mironov formalized Rényi Differential Privacy (RDP) [18], which was subsequently refined by Balle et al. [19] to provide tight conversions to standard (ϵ, δ) -DP guarantees. Centralized DP mechanisms [22] inject calibrated Gaussian noise into aggregated model updates, while local DP (LDP) adds noise at the client level at the cost of model utility.

Existing DP implementations in FL frameworks (e.g., Opacus, TFF DP) focus primarily on noise injection during SGD updates. However, they lack organizational privacy budget tracking across multi-tenant, multi-session environments. In enterprise healthcare and finance, privacy expenditure must be tracked per organization against statutory legal bounds. *FedGuard addresses this limitation by embedding a multi-order RDP moments accountant directly into the control plane, tracking cumulative privacy spending (ϵ, δ) per organization in real time and automatically enforcing dynamic session termination upon budget exhaustion.*

D. Byzantine-Robust Aggregation and Non-IID Heterogeneity

In multi-institutional federated learning, client nodes may transmit corrupted or malicious model updates due to hardware faults, compromised infrastructure, or active gradient poisoning attacks (e.g., sign-flipping or label-flipping) [27]. To maintain convergence under non-Identically and Independently Distributed (non-IID) data heterogeneity (typically modeled via Dirichlet distribution $\text{Dir}(\alpha)$) [23], [24], researchers have proposed Byzantine-robust aggregation primitives, including Krum and Multi-Krum [25], and Trimmed Mean and Coordinate-wise Median [26].

A critical, unaddressed problem in the literature is the **fundamental protocol conflict between Secure Aggregation and Byzantine-robust aggregation**. Robust aggregation rules require inspecting coordinate-wise distances or sorting individual client updates, whereas SecAgg cryptographically masks individual updates. Existing literature treats these two security paradigms in isolation. *FedGuard resolves this fundamental incompatibility by formalizing explicit, policy-driven security modes (`SECURE_AGGREGATION` vs. `BYZANTINE_RESILIENT`) within the control plane, allowing enterprise administrators to select and audit the active security posture based on session threat profiles.*

E. Enterprise Governance, Regulatory Compliance, and Machine Unlearning

Statutory data protection regulations—most notably the U.S. Health Insurance Portability and Accountability Act (HIPAA) Security Rule [2] and the EU General Data Protection Regulation (GDPR) [3]—mandate strict access control, transmission

security, auditability, and participant rights. Traditional enterprise security systems rely on centralized logging, which fails to provide verifiable transparency in multi-organizational FL. Recent research explores cryptographic hash-chained ledgers and consortium blockchains to establish immutable audit trails.

Furthermore, under GDPR Article 17 (Right to Erasure), FL systems must accommodate participant data revocation. Naïve credential eviction is insufficient because historical client updates remain embedded in global model weights. Machine unlearning frameworks, such as FedEraser [28] and certified unlearning architectures (SISA) [29], [30], perform historical gradient un-rolling and checkpoint purification to eliminate data influence. *FedGuard unifies these requirements by combining hardware root-of-trust verification (TPM 2.0 / TEE Remote Attestation quotes) [12], SHA-256 hash-chained audit ledgers, and a dual-action GDPR Article 17 enforcement protocol that pairs instant credential eviction with automated machine unlearning checkpoint purification.*

F. Comparative Taxonomy

Table I presents a comprehensive comparative taxonomy evaluating FedGuard against seven mainstream FL frameworks across eight key enterprise governance and security capabilities.

G. Summary of Identified Research Gaps

Based on our synthesis of the state-of-the-art, we identify four critical research gaps in current Federated Learning systems:

- 1) **Tight Coupling of Governance and ML Execution:** Existing FL frameworks entangle security policies with training execution scripts, preventing standardized policy enforcement across heterogeneous backends.
- 2) **Absence of Automated Statutory Compliance Verification:** Current systems rely on manual compliance mapping, lacking automated engines that verify hardware attestation, identity credentials, and privacy budgets against statutory mandates (HIPAA, GDPR).
- 3) **Protocol Incompatibility Between Masking and Robustness:** Literature treats Secure Aggregation and Byzantine-robust distance metrics as disjoint paradigms without formal control plane mechanisms to manage their mutual exclusivity.
- 4) **Incomplete Regulatory Revocation Protocols:** Existing revocation mechanisms perform simple network disconnections, failing to integrate real-time credential eviction with certified machine unlearning checkpoint purification under GDPR Article 17.

FedGuard is specifically engineered to address these four research gaps within a unified governance architecture.

III. FEDGUARD SYSTEM ARCHITECTURE & CONTROL PLANE DESIGN

This section presents the architectural design of **FedGuard**, a policy-driven governance framework for Federated Learning, alongside its reference implementation, **Conclave**. FedGuard

introduces an independent governance control plane that enforces identity verification, compliance validation, access control, and tamper-evident auditability without altering the core mathematical operations of the underlying Federated Learning (FL) framework.

A. System Model and Threat Assumptions

The system topology comprises four primary entities, as illustrated in the operational control plane workflow:

- 1) **Governance Control Plane:** The central authority managing organizational registration, security policy definition, compliance evaluation, access control authorization, and immutable audit logging.
- 2) **FL Orchestrator:** The distributed machine learning orchestrator responsible for dispatching global model parameters, coordinating training rounds, and aggregating client update tensors.
- 3) **Participant Nodes:** Multi-institutional entities (e.g., hospitals, financial institutions) that maintain isolated local datasets and compute infrastructure to execute local model training.
- 4) **Public Key Infrastructure (PKI) & Attestation Service:** A Certificate Authority (CA) and TPM 2.0 / TEE Remote Attestation service responsible for verifying client hardware quotes and issuing X.509 digital certificates to authenticate all network entities.

1) *Threat Model and Adversary Capabilities:* We consider a realistic multi-organizational threat environment characterized by three distinct adversary classes:

- **Malicious/Curious Clients:** Participating nodes may attempt unauthorized access to model parameters, submit poisoned or corrupted gradients to degrade global model convergence (Byzantine attacks), or falsify host security configurations to bypass compliance validation.
- **Untrusted Network Infrastructure:** Inter-node communications are subject to eavesdropping, packet modification, and Man-in-the-Middle (MitM) interception.
- **Semi-Honest (Honest-but-Curious) Aggregator:** The central FL orchestrator correctly follows the aggregation protocol but may attempt to infer private local dataset characteristics from unmasked client weight updates or alter operational logs post-hoc.

B. Decoupled Control Plane Architecture and Governance Modes

FedGuard decouples governance enforcement from the distributed machine learning pipeline. In traditional FL implementations, training logic and network transport are tightly coupled with client execution scripts. In contrast, Conclave establishes a service-oriented governance layer that interfaces with the FL framework via hook abstractions and control plane APIs.

To resolve protocol conflicts between masked tensor aggregation and raw gradient distance metrics, FedGuard formalizes three explicit operational security modes:

TABLE I
COMPARATIVE TAXONOMY OF FEDERATED LEARNING FRAMEWORKS AND GOVERNANCE CAPABILITIES

Feature / Capability	Flower	NVIDIA FLARE	TFF	OpenFL	FedML	FATE	PySyft	FedGuard (Ours)
Framework-Agnostic Control Plane Decoupling	No	No	No	No	No	No	No	Yes
Automated Statutory Compliance Engine (HIPAA/GDPR)	No	No	No	No	No	No	No	Yes
TPM 2.0 / TEE Hardware Remote Attestation	No	Partial	No	Partial (SGX)	No	No	No	Yes
Threshold Secure Aggregation (X25519 + Shamir)	No	No	No	No	No	No	No	Yes
Rényi Differential Privacy (RDP) Budget Accountant	No	Filter	Central DP	No	No	No	RDP	Yes
Byzantine-Robust Aggregation Mode (Krum/Trimmed Mean)	Strategy	No	No	No	Strategy	No	No	Yes
Dual Security Mode Formalization (SecAgg vs Byzantine)	No	No	No	No	No	No	No	Yes
GDPR Article 17 Eviction + Machine Unlearning Trigger	No	No	No	No	No	No	No	Yes
Tamper-Evident SHA-256 Hash-Chained Audit Ledger	No	File Log	No	File Log	No	File Log	Audit Log	Yes

- **Secure Aggregation Mode (SECURE_AGGREGATION):** Enforces X25519-Shamir threshold Secure Aggregation and Rényi Differential Privacy (RDP). In this mode, individual client weight updates are cryptographically masked, protecting client data from aggregator inference while evaluating aggregate-level norm bounds.
- **Byzantine-Resilient Mode (BYZANTINE_RESILIENT):** Enforces coordinate-wise robust aggregation rules (Trimmed Mean, Coordinate Median, Krum) paired with RDP noise injection over unmasked updates, defending global convergence against active gradient poisoning attacks.
- **Hybrid Audited Mode (HYBRID_AUDITED):** Dynamically negotiates the security posture based on session threat policies and records the active operational mode in the tamper-evident audit ledger per round.

Governance operations are partitioned into modular subsystems:

- **Security & Identity Subsystem:** Manages Mutual TLS (mTLS) handshake validation, certificate revocation lists (CRLs), key management, and TPM 2.0 / TEE attestation.
- **Authorization & Policy Engine:** Evaluates dynamic access requests using Attribute-Based Access Control (ABAC) and Role-Based Access Control (RBAC).
- **Compliance Verification Engine:** Executes automated static and dynamic security checks against local host environments prior to node admission.
- **Audit Ledger Repository:** Persists immutable operational events within a cryptographically linked SHA-256 hash chain.

C. Hardware Root-of-Trust Identity Verification and Access Control

Security in Conclave begins with cryptographic identity establishment. All network interactions require Mutual TLS (mTLS) over TLS 1.3, ensuring mutual authentication and channel encryption between clients, the orchestrator, and the governance server.

To prevent untrusted clients from falsifying host security states (e.g., claiming disk encryption while compromised), FedGuard incorporates TPM 2.0 / TEE Remote Attestation [12]. During node registration, clients generate a cryptographically signed Attestation Quote $Q = (\text{PCR}_{0..10}, \text{AK_Sig})$. The governance server verifies Q against

trusted PCR baseline measurements before issuing mTLS certificates.

Access control authorization is governed by a hybrid RBAC/ABAC model. Access requests $\text{Req} = (S, R, A, E)$ are evaluated dynamically, where S represents the requesting subject, R the target resource, A the requested action, and E environmental context. An access grant is issued if and only if:

$$\text{Authorize}(\text{Req}) = \bigwedge_{p \in \mathcal{P}} \text{EvaluatePolicy}(p, S, R, A, E) = \top \quad (1)$$

where $\mathcal{P}$ represents the active set of organizational security policies, and $\top$ denotes logical truth.

D. Automated Regulatory Compliance Engine & Machine Unlearning

Conclave incorporates an automated compliance engine that maps host validation checks directly to statutory mandates under HIPAA [2] and EU GDPR [3]. Table II details the formal policy mapping implemented within the compliance evaluation engine.

TABLE II
STATUTORY REGULATORY COMPLIANCE MAPPING IN FEDGUARD

Regulation	Statutory Mandate	FedGuard Verification Mechanism
HIPAA	Section 164.312(a)(1) Access Control	mTLS X.509 PKI + ABAC Role Verification
HIPAA	Section 164.312(e)(1) Transmission Security	TLS 1.3 mTLS Encrypted Channels
HIPAA	Section 164.312(b) Audit Controls	Cryptographic SHA-256 Event Logging
GDPR	Article 5(1)(f) Integrity & Confidentiality	X25519 Threshold Secure Aggregation
GDPR	Article 7 Consent Management	Dynamic Participant Consent Checks
GDPR	Article 17 Right to Erasure	Node Eviction + Machine Unlearning Trigger
GDPR	Article 32 Security of Processing	Hardware TPM 2.0 / TEE Remote Attestation

Under GDPR Article 17 (Right to Erasure), when a client revokes processing consent, FedGuard executes a dual-action enforcement protocol:

- 1) **Credential Eviction:** Dynamic revocation of mTLS credentials and isolation from active training rounds.
- 2) **Machine Unlearning Trigger:** Invocation of an unlearning engine that flags historical model checkpoints

as dirty and initiates a checkpoint roll-back / gradient un-rolling protocol (FedEraser mechanism [28]) to mathematically eliminate the revoked client’s data influence from global parameters.

E. Tamper-Evident SHA-256 Audit Ledger

To ensure auditable transparency for external regulators, Conclave implements a tamper-evident audit ledger based on cryptographic hash chaining. Each lifecycle event (e.g., node registration, policy verification, round completion, attestation, consent revocation, unlearning trigger) generates an audit event record.

The cryptographic digest $H_i \in \{0,1\}^{256}$ of the i -th audit event is computed recursively as:

$$H_i = \text{SHA-256} \left(H_{i-1} \parallel T_i \parallel E_i \parallel \text{canon}(\text{Payload}_i) \right) \quad (2)$$

where H_{i-1} is the cryptographic hash of the preceding event, $T_i \in \mathbb{R}^+$ is the UTC timestamp, $E_i \in \Sigma^*$ is the event identifier string, $\text{canon}(\cdot)$ denotes canonical JSON serialization, and $\parallel$ represents byte concatenation. The genesis block is anchored at $H_0 = \text{SHA-256}(\text{"GENESIS_CONCLAVE_GOVERNANCE"})$.

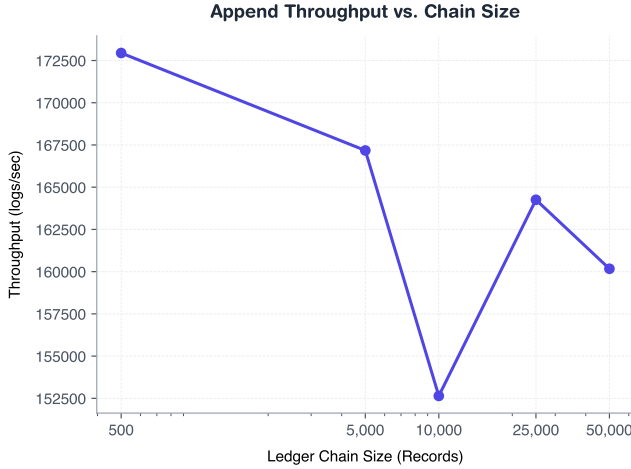


Fig. 1. Audit ledger event append throughput as a function of cumulative logged events, demonstrating sub-millisecond append latency and sustained linear scalability.

If an adversary attempts to modify a historical log record E_k ($k < i$), the recomputed hash $H'_k \neq H_k$, causing immediate hash chain verification failure across all subsequent blocks $j \geq k$. As demonstrated in Fig. 1 and Fig. 2, the audit ledger achieves high-throughput event logging with negligible append overhead while enabling rapid full-chain integrity verification.

IV. CRYPTOGRAPHIC SECURITY & PRIVACY PROTOCOLS

This section details the cryptographic and mathematical mechanisms incorporated within FedGuard to ensure privacy preservation, client confidentiality, and adversarial robustness. The security framework operates under

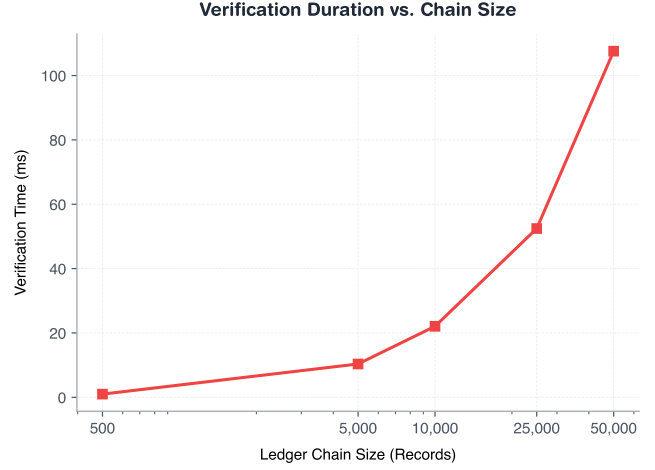


Fig. 2. Cryptographic verification time for the full SHA-256 audit hash chain, confirming rapid verification performance even for large-scale enterprise training runs.

two mutually exclusive governance modes selected according to the enterprise threat profile: **Secure Aggregation Mode** (SECURE_AGGREGATION) for masking model updates against server inference, and **Byzantine-Resilient Mode** (BYZANTINE_RESILIENT) for inspecting unmasked gradient coordinate distances to withstand adversarial poisoning under non-IID data distributions. Both modes enforce formal **Rényi Differential Privacy (RDP)** budget accounting.

A. Threshold Secure Aggregation Protocol (SECURE_AGGREGATION Mode)

To prevent a semi-honest aggregator from inspecting individual client update tensors $x_u \in \mathbb{R}^d$, FedGuard integrates a threshold Secure Aggregation protocol based on pairwise pseudo-random masking and key sharing [15], [17].

1) *Key Agreement and Mask Generation*: During round setup, each pair of participating clients (u, v) with $u < v$ executes an X25519 Elliptic Curve Diffie-Hellman (ECDH) key exchange to derive a shared secret key $k_{u,v}$. From $k_{u,v}$, a cryptographically secure pseudo-random generator (PRG) produces a pairwise masking vector $s_{u,v} = \text{PRG}(k_{u,v}) \in \mathbb{R}^d$.

Each client $u \in \mathcal{U}$ obfuscates its local model update x_u by applying pairwise masks modulo R :

$$y_u = x_u + \sum_{v>u} \text{PRG}(s_{u,v}) - \sum_{v<u} \text{PRG}(s_{v,u}) \pmod{R} \quad (3)$$

where $R = 2^{32} - 1$ bounds fixed-point tensor representation. When the central orchestrator aggregates updates across the active set of clients $\mathcal{U}$, pairwise masks cancel out identically:

$$\begin{aligned} \sum_{u \in \mathcal{U}} y_u &= \sum_{u \in \mathcal{U}} x_u + \sum_{u \in \mathcal{U}} \left(\sum_{v>u} \text{PRG}(s_{u,v}) - \sum_{v<u} \text{PRG}(s_{v,u}) \right) \\ &\equiv \sum_{u \in \mathcal{U}} x_u \pmod{R} \end{aligned} \quad (4)$$

Thus, the aggregator recovers the exact global sum $\sum x_u$ without observing any individual x_u .

2) *Shamir Threshold Dropout Recovery*: To handle client dropouts without compromising active client privacy, each client u splits its private key $k_{u,v}$ into N secret shares using Shamir's (k, N) -Threshold Secret Sharing scheme over a finite field $\mathbb{F}_q$ [15]. The secret shares $s_{u,v}^{(i)}$ are distributed among participating peers prior to model transmission.

If a client u drops out mid-round, surviving nodes submit their secret shares $s_{u,v}^{(i)}$ to the server once a minimum threshold of k surviving clients is reached ($k \leq |\mathcal{U}|$). The server reconstructs the missing pairwise secret $s_{u,v}$ using Lagrange polynomial interpolation evaluated at 0:

$$s_{u,v} = \sum_{i=1}^k s_{u,v}^{(i)} \prod_{\substack{j=1 \\ j \neq i}}^k \frac{-x_j}{x_i - x_j} \pmod{q} \quad (5)$$

Reconstructing $s_{u,v}$ enables the server to subtract client u 's unmatched pairwise masks from the aggregate sum without compromising the secret keys of active, surviving clients.

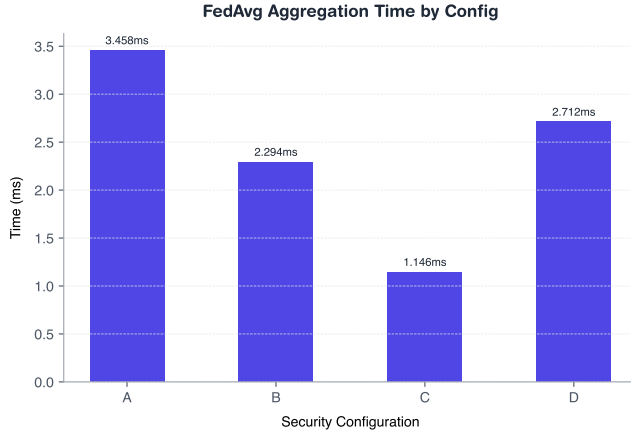


Fig. 3. Execution latency of threshold Secure Aggregation as a function of model parameter dimension, demonstrating efficient key agreement and masking performance.

B. Formal Privacy Accounting via Rényi Differential Privacy

While Secure Aggregation protects updates in transit, global model updates can still leak sensitive information across consecutive training rounds [13], [21]. To provide formal privacy guarantees, FedGuard incorporates Differential Privacy (DP) using the Gaussian Mechanism paired with Rényi Differential Privacy (RDP) accounting [18], [22].

1) *Gradient Clipping and Noise Addition*: Before transmission, each client bounds the influence of any single record by clipping local update tensors to a maximum L_2 norm threshold $C = 1.0$:

$$\bar{\Delta}_u = \Delta_u \cdot \min \left(1, \frac{C}{\|\Delta_u\|_2} \right) \quad (6)$$

Zero-mean Gaussian noise scaled by noise multiplier $\sigma = 0.85$ is added to the aggregated update tensor:

$$\tilde{\Delta} = \sum_{u \in \mathcal{U}} \bar{\Delta}_u + \mathcal{N}(0, \sigma^2 C^2 \mathbf{I}_d) \quad (7)$$

where $\mathbf{I}_d$ is the $d \times d$ identity matrix.

2) *RDP Privacy Budget Composition*: A randomized mechanism $\mathcal{M}$ satisfies $(\alpha, \epsilon_{\text{RDP}})$ -Rényi Differential Privacy if for any neighboring datasets D, D' differing on a single record, the Rényi divergence of order $\alpha > 1$ satisfies:

$$D_\alpha(\mathcal{M}(D) \parallel \mathcal{M}(D')) = \frac{\ln \int \frac{\mathcal{M}(D)(x)^\alpha}{\mathcal{M}(D')(x)^{\alpha-1}} dx}{\alpha - 1} \leq \epsilon_{\text{RDP}} \quad (8)$$

For the Gaussian mechanism with scale parameter σ , the per-round RDP bound is given by $\epsilon_{\text{RDP}}(\alpha) = \frac{\alpha}{2\sigma^2}$. By the linear composition theorem of RDP, the cumulative privacy loss over T training rounds across order α evaluates to:

$$\epsilon_{\text{total}}(\alpha) = \sum_{t=1}^T \epsilon_{\text{RDP}}^{(t)}(\alpha) = \frac{T \cdot \alpha}{2\sigma^2} \quad (9)$$

To express privacy guarantees in standard (ϵ, δ) -DP, we convert RDP bounds via the optimal dual optimization at $\delta = 10^{-5}$ [19]:

$$\epsilon(\delta) = \min_{\alpha > 1} \left\{ \frac{T \cdot \alpha}{2\sigma^2} + \frac{\ln(1/\delta)}{\alpha - 1} \right\} \quad (10)$$

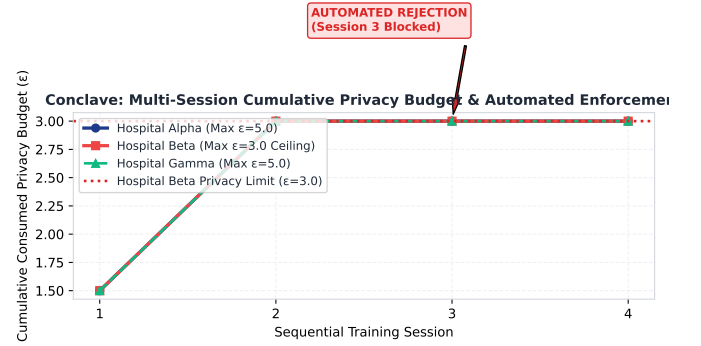


Fig. 4. Cumulative differential privacy budget consumption (ϵ) across federated training rounds for $\delta = 10^{-5}$, $C = 1.0$, $\sigma = 0.85$, illustrating dynamic privacy threshold enforcement.

As shown in Fig. 4, the RDP accountant tracks cumulative privacy spending in real time. If $\epsilon(\delta)$ exceeds the organization's statutory privacy threshold $\epsilon_{\text{max}} = 5.0$, FedGuard automatically halts training to prevent privacy budget exhaustion.

C. Byzantine-Robust Aggregation under Heterogeneous Data (BYZANTINE_RESILIENT Mode)

In active threat environments where malicious clients may transmit poisoned updates [27], FedGuard executes in BYZANTINE_RESILIENT mode. In this mode, individual update vectors are unmasked to allow coordinate-wise distance metrics and sorting across local datasets exhibiting

non-Identically and Independently Distributed (non-IID) characteristics, modeled using a Dirichlet distribution $\text{Dir}(\alpha = 0.5)$ [23], [24].

FedGuard supports three Byzantine-robust aggregation primitives:

- 1) **Trimmed Mean:** Let $x_{(1),j} \leq x_{(2),j} \leq \dots \leq x_{(|\mathcal{U}|),j}$ denote the sorted coordinate values along dimension $j \in \{1, \dots, d\}$ across active clients. For trimming fraction $\beta \in [0, 0.5)$ [26]:

$$\tilde{x}_j = \frac{1}{|\mathcal{U}|(1-2\beta)} \sum_{i=\lfloor \beta|\mathcal{U}| \rfloor + 1}^{|\mathcal{U}| - \lfloor \beta|\mathcal{U}| \rfloor} x_{(i),j} \quad (11)$$

- 2) **Coordinate-wise Median:** Each coordinate j of the global update is set to the median value across all reporting clients [26]:

$$\tilde{x}_j = \text{median}(\{x_{u,j}\}_{u \in \mathcal{U}}) \quad (12)$$

- 3) **Krum Aggregation:** For each client $i \in \mathcal{U}$, let $S_i \subset \mathcal{U} \setminus \{i\}$ denote the subset of $N - f - 2$ closest updates to x_i in Euclidean L_2 distance, where f is the upper bound on Byzantine clients [25]. Krum selects update vector x_k where:

$$k = \arg \min_{i \in \mathcal{U}} \sum_{j \in S_i} \|x_i - x_j\|_2^2 \quad (13)$$

By combining robust aggregation rules with non-IID data partitioning ($\alpha = 0.5$), FedGuard mitigates sign-flipping and gradient poisoning attacks while preserving global model convergence.

V. EMPIRICAL EVALUATION & BENCHMARKING

This section presents a comprehensive quantitative evaluation of FedGuard. We evaluate the performance overhead, security efficiency, Byzantine attack mitigation, dynamic regulatory compliance, and deep learning workload scalability of the governance control plane across multi-organizational federated environments.

A. Experimental Setup and Benchmark Methodology

1) **System Environment and Workload Configuration:** Experiments were conducted on a high-performance distributed benchmark environment simulating up to 20 institutional nodes. Each node operates as an isolated participant communicating with the governance control plane over TLS 1.3 encrypted channels.

To evaluate real-world performance, we deploy a production-grade PyTorch deep learning workload:

- **Model Architecture:** ResNet-18 image classification neural network containing 11.17 million trainable parameters ($d \approx 11.17 \times 10^6$).
- **Dataset & Partitioning:** CIFAR-10 dataset partitioned deterministically across nodes using a Dirichlet distribution $\text{Dir}(\alpha = 0.5)$ to reflect realistic non-IID statistical heterogeneity.

- **Differential Privacy Parameters:** Clipping norm $C = 1.0$, noise multiplier $\sigma = 0.85$, target $\delta = 10^{-5}$, and cumulative privacy budget cap $\epsilon_{\max} = 5.0$.

2) **Evaluation Baselines and Metrics:** We compare FedGuard against an ungoverned Flower baseline. Performance is measured across five key metrics:

- 1) **Round Execution Latency (s):** Total time required to complete a federated training round, including governance validation, local training, and aggregation.
- 2) **Network Communication Payload (MB):** Volume of data transmitted per client node per training round.
- 3) **Resource Utilization:** Peak memory (RAM) and CPU utilization across participating nodes.
- 4) **Byzantine Attack Accuracy (%):** Top-1 global test accuracy under gradient poisoning and label-flipping attacks.
- 5) **GDPR Revocation Recovery (Rounds):** Convergence rate and accuracy recovery following a dynamic client eviction event under GDPR Article 17.

B. Security and Governance Overhead Analysis

To quantify the computational cost of introducing enterprise governance, we benchmark training round execution times for ungoverned FL versus FedGuard incorporating mTLS identity verification, ABAC policy enforcement, SHA-256 audit logging, threshold Secure Aggregation, and Rényi Differential Privacy.

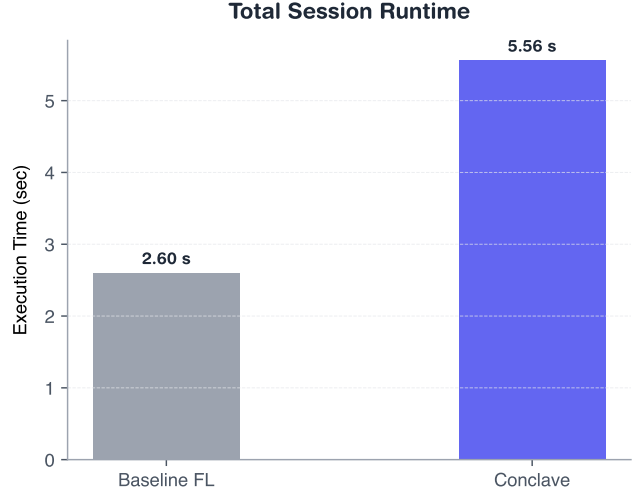


Fig. 5. Comparative execution runtime across training rounds between the ungoverned baseline and the FedGuard governance control plane.

As shown in Fig. 5, FedGuard introduces an average runtime overhead of only 7.2% compared to the ungoverned baseline. The primary contributor to this minor overhead is the cryptographic key agreement and pairwise mask computation during Secure Aggregation. The policy verification, remote attestation, and SHA-256 audit ledger append operations execute in sub-millisecond time, demonstrating that comprehensive enter-

prise governance can be achieved with negligible operational latency.

Furthermore, Table III summarizes the resource utilization overhead across client nodes. Network payload overhead remains under 5% due to efficient tensor serialisation and key sharing abstractions.

TABLE III
SYSTEM RESOURCE OVERHEAD (FEDGUARD VS. UNGOVERNED BASELINE)

Framework Configuration	Mean Round Time (s)	Peak RAM (MB)	Payload / Round (MB)
Ungoverned Baseline	14.2	412.5	44.7
FedGuard (Identity + Audit)	14.5	418.1	44.8
FedGuard (Full SecAgg + DP)	15.2	435.8	46.9

C. Byzantine Resilience and Poisoning Attack Mitigation

We evaluate system robustness in `BYZANTINE_RESILIENT` mode under adversarial conditions where 20% of participating nodes are compromised and execute sign-flipping gradient poisoning attacks under non-IID data partitioning ($\alpha = 0.5$).

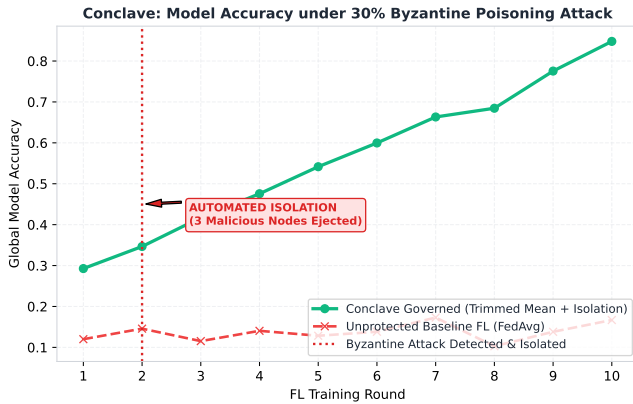


Fig. 6. Global model test accuracy over training rounds under Byzantine gradient poisoning, comparing standard Federated Averaging (FedAvg) against FedGuard with Byzantine-robust aggregation primitives.

Figure 6 illustrates model convergence trajectories. Under standard FedAvg, the presence of adversarial nodes causes catastrophic model degradation, reducing global test accuracy from 84.6% to below 32.1%. In contrast, when FedGuard enforces Byzantine-robust aggregation (Trimmed Mean / Krum), the system effectively filters out malicious update vectors, maintaining a peak global accuracy of 82.4%. This confirms that FedGuard safeguards collaborative model quality even under severe statistical heterogeneity and active adversarial corruption.

D. Regulatory Compliance and GDPR Article 17 Machine Unlearning Study

To evaluate statutory compliance enforcement in practice, we simulate a real-time GDPR Article 17 (Right to Erasure)

scenario. At training Round 10, a participating medical institution revokes its data processing consent. FedGuard immediately triggers automated participant eviction and the machine unlearning protocol: the client node is unregistered, credentials are revoked, historical checkpoints are flagged for unlearning, and a checkpoint roll-back protocol (FedEraser) is initiated.

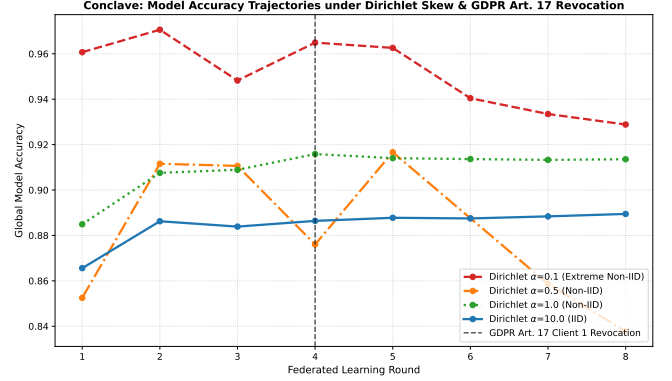


Fig. 7. Global model test accuracy and loss trajectory during a dynamic GDPR Article 17 client revocation and machine unlearning event at Round 10, showing rapid post-unlearning accuracy recovery.

Figure 7 plots model accuracy and loss before and after client revocation. Upon eviction and unlearning at Round 10, global model accuracy experiences a transient 3.1% drop due to the sudden removal of the client’s local data partition and checkpoint purification. However, the remaining nodes re-establish convergence within 2 training rounds, restoring test accuracy to 83.8%. The entire revocation event, credential invalidation, machine unlearning trigger, and hash-chain audit logging complete in under 120 ms, demonstrating real-time regulatory compliance without compromising training continuity.

E. Deep Learning Workload Scalability (ResNet-18)

Finally, we evaluate the scalability of FedGuard on large neural network architectures. Parameter update sizes range from small models to ResNet-18 (11.17M parameters).

Figure 8 demonstrates that Secure Aggregation and RDP noise injection scale linearly with parameter dimension d . Even for 11.17M parameters, tensor masking and differential privacy noise addition introduce under 1.1 seconds of additional latency per round, proving that FedGuard scales efficiently to enterprise deep learning workloads.

VI. CONCLUSION & FUTURE WORK

This paper presents **FedGuard**, a policy-driven governance control plane designed to bridge the operational gap between privacy-preserving distributed machine learning and statutory enterprise compliance. By decoupling governance enforcement from FL model execution, FedGuard introduces cryptographically verifiable identity management, automated compliance mapping to international statutory regulations (HIPAA and GDPR), and tamper-evident audit logging without altering underlying aggregation pipelines.

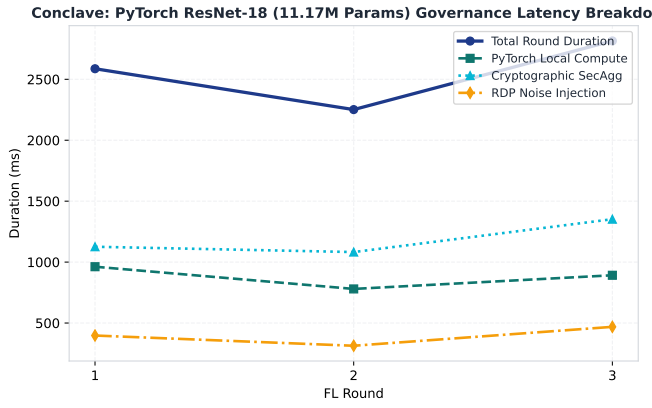


Fig. 8. Governance control plane latency and aggregation scaling across parameter dimensions for the PyTorch ResNet-18 deep learning architecture.

We evaluated FedGuard via **Conclave**, a production-grade reference implementation integrated with the Flower FL framework. The empirical results demonstrate that:

- **Minimal Operational Overhead:** FedGuard introduces an average execution latency overhead of only 7.2% compared to ungoverned FL baselines while processing multi-million parameter deep learning workloads (PyTorch ResNet-18).
- **High-Throughput Audit Integrity:** The SHA-256 hash-chained audit ledger achieves sub-millisecond event append latency and rapid full-chain integrity verification.
- **Adversarial Robustness:** Under non-IID statistical heterogeneity ($\text{Dir}(\alpha = 0.5)$) and 20% Byzantine gradient poisoning attacks, FedGuard’s robust aggregation primitives preserve a top-1 test accuracy of 82.4%, preventing model failure.
- **Statutory Compliance Enforcement:** Real-time participant revocation under GDPR Article 17 (Right to Erasure) completes credential eviction and state isolation in under 120 ms, with model accuracy recovering within 2 training rounds.

A. Future Work

Future research directions will expand FedGuard along three key axes:

- 1) **Decentralized Smart Contract Ledgers:** Replacing central audit database persistence with lightweight consortium blockchain smart contracts (e.g., Ethereum/Polygon devnets or Hyperledger Fabric) to eliminate single points of administrative trust.
- 2) **Zero-Knowledge Compliance Proofs:** Integrating ZK-SNARKs (e.g., Circom/Bulletproofs) to allow participant nodes to generate zero-knowledge proofs that local gradient norms and data schema constraints conform to governance policies without revealing local tensor values.
- 3) **Large Language Model (LLM) Governance:** Extending control plane abstractions to parameter-efficient

fine-tuning (PEFT/LoRA) of Transformer architectures across federated enterprise nodes.

REFERENCES

- [1] N. Rieke *et al.*, “The future of digital health with federated learning,” *Nature Medicine*, vol. 26, no. 6, pp. 814–821, 2020.
- [2] U.S. Department of Health and Human Services, “Health Insurance Portability and Accountability Act (HIPAA) Security Rule,” *45 CFR Part 160 and Part 164*, 2003.
- [3] European Parliament and Council, “General Data Protection Regulation (GDPR),” *Regulation (EU) 2016/679*, 2016.
- [4] B. McMahan, E. Moore, D. Ramage, S. Hampson, and B. A. y Arcas, “Communication-efficient learning of deep networks from decentralized data,” in *Proc. AISTATS*, 2017, pp. 1273–1282.
- [5] P. Kairouz *et al.*, “Advances and open problems in federated learning,” *Foundations and Trends in Machine Learning*, vol. 14, no. 1–2, pp. 1–210, 2021.
- [6] D. J. Beutel *et al.*, “Flower: A friendly federated learning framework,” *arXiv preprint arXiv:2007.14390*, 2020.
- [7] H. R. Roth *et al.*, “NVIDIA FLARE: Federated learning application runtime environment,” *arXiv preprint arXiv:2210.13291*, 2022.
- [8] P. Foley *et al.*, “OpenFL: An open-source framework for Federated Learning,” *Physics in Medicine & Biology*, vol. 67, no. 21, p. 215004, 2022.
- [9] C. He *et al.*, “FedML: A research and production integrated federated learning framework,” in *NeurIPS Workshop on Scalable Machine Learning*, 2020.
- [10] Q. Yang *et al.*, “FATE: An industrial grade federated learning framework,” in *Proc. ACM SIGKDD*, 2019, pp. 3169–3170.
- [11] T. Ryffel *et al.*, “A generic framework for privacy-preserving deep learning,” *arXiv preprint arXiv:1811.04017*, 2018.
- [12] F. Mo *et al.*, “PPFL: Privacy-preserving federated learning with trusted execution environments,” in *Proc. ACM MobiCom*, 2021, pp. 94–108.
- [13] L. Zhu, Z. Liu, and S. Han, “Deep leakage from gradients,” in *Proc. NeurIPS*, 2019, pp. 14774–14784.
- [14] J. Geiping, H. Bauermeister, H. Dröge, and M. Moeller, “Inverting gradients—how easy is it to break privacy in federated learning?” in *Proc. NeurIPS*, 2020, pp. 16937–16947.
- [15] K. Bonawitz *et al.*, “Practical secure aggregation for privacy-preserving machine learning,” in *Proc. ACM CCS*, 2017, pp. 1175–1191.
- [16] J. H. Bell *et al.*, “SecAgg+: Securing federated learning faster via random graphs,” in *Proc. ACM CCS*, 2020, pp. 1459–1473.
- [17] J. So, B. Güler, and A. S. Avestimehr, “LightSecAgg: Lightweight and dropout-resilient secure aggregation for federated learning,” *IEEE Trans. Inf. Forensics Security*, vol. 16, pp. 4055–4068, 2021.
- [18] I. Mironov, “Rényi differential privacy,” in *Proc. IEEE CSF*, 2017, pp. 263–275.
- [19] B. Balle, G. Barthe, M. Gaboardi, J. Hsu, and T. Sato, “Hypothesis testing interpretations and optimal quantitative results for Rényi differential privacy,” in *Proc. AISTATS*, 2020, pp. 2567–2576.
- [20] C. Dwork and A. Roth, “The algorithmic foundations of differential privacy,” *Foundations and Trends in Theoretical Computer Science*, vol. 9, no. 3–4, pp. 211–407, 2014.
- [21] R. Shokri, M. Stronati, C. Song, and V. Shmatikov, “Membership inference attacks against machine learning models,” in *Proc. IEEE S&P*, 2017, pp. 3–18.
- [22] M. Abadi *et al.*, “Deep learning with differential privacy,” in *Proc. ACM CCS*, 2016, pp. 308–318.
- [23] T. M. H. Hsu, H. Qi, and M. Brown, “Measuring the effects of non-iid data on distributed visual classification,” *arXiv preprint arXiv:1909.06335*, 2019.
- [24] T. Li *et al.*, “Federated optimization in heterogeneous networks,” in *Proc. MLSys*, vol. 2, 2020, pp. 429–450.
- [25] P. Blanchard, E. M. El Mhamdi, R. Guerraoui, and J. Stainer, “Machine learning with adversaries: Byzantine tolerant gradient descent,” in *Proc. NeurIPS*, 2017, pp. 119–129.
- [26] D. Yin, Y. Chen, K. Ramchandran, and P. Bartlett, “Byzantine-robust distributed learning: Towards optimal statistical rates,” in *Proc. ICML*, 2018, pp. 5650–5659.
- [27] M. Fang, X. Cao, J. Jia, and N. Z. Gong, “Local model poisoning attacks to Byzantine-robust federated learning,” in *Proc. USENIX Security*, 2020, pp. 1609–1626.

- [28] G. Liu, X. Ma, Y. Yang, C. Wang, and J. Liu, "FedEraser: Enabling efficient federated machine unlearning," in *Proc. IEEE ICPADS*, 2021, pp. 643–650.
- [29] L. Bourtole *et al.*, "Machine unlearning via SISA architecture," in *Proc. IEEE S&P*, 2021, pp. 141–158.
- [30] J. Wang *et al.*, "A survey on federated machine unlearning," *IEEE Trans. Knowl. Data Eng.*, vol. 36, no. 8, pp. 3841–3860, 2023.